

EXPLOITED VULNERABILITY ADVISORY: CVE-2026-85706

Summary

CVE-2026-85706 in GitLab Community Edition and Enterprise Edition is being actively exploited in the wild. GitLab has remediated an issue in GitLab CE/EE affecting all versions from 18.7 before 19.1.8, 19.2 before 19.2.6, and 19.3 before 19.3.2 that, under certain conditions, an unauthenticated user could have read arbitrary files from the GitLab server due to improper path confinement and missing authentication enforcement in the repository commits API. CISA requires federal remediation by 2026-09-14; under the CRA, exploitation of an affected product must be reported within 24 hours.

What we know

- **CVE:** CVE-2026-85706
- **Affected:** GitLab Community Edition and Enterprise Edition
- **Exploitation:** Actively exploited, added to CISA KEV on 2026-09-11
- **Severity:** CVSS 10.0 Critical, Network-exploitable, no privileges required, no user interaction (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:N)
- **Exploitation likelihood (EPSS):** 1%
- **Weakness:** CWE-35

Recommended action

Patch CVE-2026-85706 by 2026-09-14. If you cannot patch immediately, restrict network access to the affected service now (segment it, put it behind a VPN, or take it offline) until you can patch. If you ship an affected product, be ready to file the CRA 24-hour report the moment you find it exploited.

Sources: CISA Known Exploited Vulnerabilities, NIST NVD. Public data; an advisory of active exploitation, not an incident report. Verify applicability to your estate before acting.